

Cisco Secure Workload - TISAX / VDA ISA Compliance Report

Cisco Secure Workload - TISAX / VDA ISA Compliance Report

Customer-Facing Compliance Report

Framework: TISAX (Trusted Information Security Assessment Exchange) - assessment of the VDA ISA (Information Security Assessment) catalogue

Primary audience: Automotive suppliers, OEM partners, and engineering / development service providers preparing for, maintaining, or renewing a TISAX assessment.

CSW positioning: Information security level evidence, prototype-protection segmentation, data-protection segmentation, and supplier readiness for the ENX/TISAX assessment.

Framework Version Note

TISAX is the assessment label operated by the ENX Association; VDA ISA is the underlying control catalogue. VDA ISA has multiple published versions (5.x at time of writing). This report references VDA ISA topic areas by name, not specific control numbers, because control numbering may vary across catalogue versions. Validate against the VDA ISA workbook version applicable to your assessment scope and assessment objectives (AL 1 / AL 2 / AL 3 / AL High / AL Very High).

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-TISAX-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

TISAX

- └ Information-Security-Scope (Production-Workloads, Engineering-Workloads, Corporate-Adjacent)
- └ Prototype-Protection-Scope (only when in assessment scope)
- └ Data-Protection-Scope (only when in assessment scope)
- └ Security-Services
- └ Supplier-Edges

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Asset Management (workload inventory, labels, reachability)
- Communication Security (workload-level segmentation)
- Operations Security (continuous monitoring, vulnerability + reachability)
- Identity and Access Management (workload-to-workload layer)
- Information Security Incident Management (forensic flow / process telemetry)
- Prototype Protection (when in scope - isolation evidence)
- Data Protection (when in scope - isolation evidence)
- Supplier Relationships (outbound flow visibility)
- Compliance (evidence pack inputs)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Information Security Policies and Organisation (governance)

- Personnel / HR controls
- Physical Security (including prototype physical handling)
- System Acquisition, Development, Maintenance (code-level controls)
- Cryptography (CSW detects plaintext flows but does not enforce encryption)
- Portability and Interoperability

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Asset Management	Direct	Workload inventory; scope + label export	Inventory and classification evidence at workload layer
Communication Security	Direct	Policy workspace; ADM-derived allowlist; observed flows	Segmentation evidence (workspace snapshot + observed- vs-approved flow comparison)
Operations Security	Direct	Continuous monitoring; vulnerability + reachability; configuration baseline on policy	Operations control evidence
Identity and Access Management (workload-to- workload)	Supporting	Policy workspace + enforcement / violation log	Workload-to- workload privilege evidence (complements identity layer)
Cryptography (detection)	Supporting	Plaintext-flow detection on regulated paths	Detection input only
Supplier Relationships	Supporting	Outbound flow summary to supplier endpoints	Supplier-edge flow report reconciled against supplier register
Incident Management	Direct	Forensic flow + process telemetry	Investigation pack with timeline and impact scope
Prototype Protection (if in scope)	Direct	Isolation evidence for the Prototype- Protection scope	Inbound/outbound reachability summary for prototype workloads
Data Protection (if in	Direct	Isolation evidence for	Inbound/outbound

Framework topic	Coverage	CSW capability	Evidence artifact
scope)		the Personal-Data scope	reachability summary for personal-data workloads

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Information asset and prototype/data scope mapping	Workloads in the assessment scope by label	Inventory + scope membership export filtered by assessment_objective , prototype, data_class	Monthly
Segmentation evidence	Workspace snapshot and ADM-derived allowlist	Policy workspace export + ADM export	Quarterly + after each change
Supplier egress reconciliation	Outbound flow to supplier endpoints	Flow search filtered to supplier endpoints	Monthly
Operations evidence	Continuous monitoring and vulnerability data	Vulnerability report + alert log scoped to TISAX	Monthly
Prototype-Protection isolation (if in scope)	Reachability into the prototype scope	Reach summary for the Prototype-Protection scope	Quarterly
Data-Protection isolation (if in scope)	Reachability into the personal-data scope	Reach summary for the Data-Protection scope	Quarterly
Incident sample	One representative incident timeline	Flow + process search	Per incident; one representative sample per surveillance cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.

4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. `tenant`, `prototype`, `isa_level`, `npi`, `cui`, `ephi`).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace organisational policy, training, supplier assurance contracts, physical security and prototype physical handling, identity lifecycle, cryptography assurance, or the TISAX assessment itself.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.